Receiver-Sovereign Federated Early Warning for Cross-Domain Agent Tool Use

Anonymous Submission

Abstract

Autonomous software increasingly crosses administrative boundaries while invoking consequential tools. A domain that first observes compromise may be unable to control a downstream domain, while a global enforcement service may be unacceptable for sovereignty, privacy, or outage reasons. TCOP is a receiver-sovereign federated early-warning architecture: domains exchange signed, scoped, time-bounded context, but the receiver alone performs correlation, applies policy, and issues any enforcement decision. We evaluate timing, authority, and availability consequences in deterministic matched experiments, frozen action-trace replay, and a physical reference gateway path. In the matched deterministic comparison, imported context improved 30 of 54 strict pairs and prevented 36 harmful actions, with no worsened pair. The live evaluation uses 44 captured traces and 220 strict paired replays. Physical gateway arms show that context arriving before the first harmful opportunity can change local authorization, whereas later context can reduce subsequent blast radius without reversing completed actions. The same containment-first response constrains 40 of 360 selected benign calls, making availability cost a first-class result. TCOP is not a remote kill switch, does not create detections, and is not evaluated as an Internet-scale deployment.

1 Introduction

Independently governed domains increasingly interact through autonomous software, delegated workflows, and tool-using agents. A compromise may be observed in one domain before a downstream domain can recognize the resulting requests locally. Existing local controls do not automatically transport timely runtime evidence across that governance boundary. Conversely, a global enforcement service can be infeasible: it can centralize sensitive telemetry, create a high-value outage dependency, or be institutionally unacceptable.

TCOP addresses this coordination problem without transferring enforcement authority. An origin domain exports signed and bounded TCX context. The receiving domain validates it, correlates it to its own local state, selects a receiver-local strategy and policy, and records a receiver-local decision. The imported context is evidence for a local decision, not an instruction to allow, deny, quarantine, revoke, suspend, or select a restriction duration.

The key question is timing. Imported context is useful only while it arrives within the containment window of a consequential action. It may prospectively prevent an early action, reduce blast radius after an initial action, or become forensic and coordination evidence after all relevant actions have completed. This paper evaluates that timing dependence together with authority preservation, failure behavior, and availability cost.

This paper makes four contributions:

- a receiver-sovereign architecture and signed-context protocol boundary for cross-domain early warning;
- a containment-window model that distinguishes prospective prevention from subsequent blast-radius reduction;
- deterministic matched evaluation with frozen strategies and explicit exclusions for unmatched local policies; and
- live-agent trace capture, strict replay, physical federation, and reference-gateway validation with no remote enforcement success.

2 Problem and Threat Model

We consider independently governed trust domains that run agents or automation with local observers and enforceable local choke points. Agents, observers, and peer domains can be honest, compromised, or faulty. Adversaries can relay, replay, delay, or suppress cross-domain messages; a peer can be malicious; and a network can partition. The receiving enforcement boundary is trusted only insofar as the receiver controls its policy and authorization adapter.

Table 1: TCOP design requirements.

Requirement	Mechanism
Signed provenance	Signed TCX context with authorized peer identity
Bounded scope and expiry	Scoped, time-bounded context validation
Replay protection	Receiver replay checks and fresh local decisions
Receiver-local correlation and policy	Domain B correlates and applies its own strategy and policy
No remote enforcement command	Imported context never maps directly to allow, deny, quarantine, revoke, or suspend
Capability-scoped response	Domain B restricts only locally selected capabilities
Audit linkage	Receipt and decision records link context to local action
Partition-local operation	Local controls remain available during federation failure
Explicit availability cost	Benign restriction impact is measured, not hidden

TCOP assumes that at least one participating domain detects a useful fact, that the receiver has an enforceable choke point, and that public-key identity and peer authorization exist. The receiver's policy is outside remote control. TCOP does not guarantee that any observation is true, and a cross-domain context cannot directly invoke enforcement.

Out of scope are preventing an undetected origin compromise, global consensus, replacing endpoint, identity, or monitoring systems, real-world actor attribution, production-scale Internet federation, and rollback of completed harmful actions. The implementation evaluates a bounded synthetic reference deployment rather than an uninstrumented incident.

3 Architecture and Protocol Boundary

Each domain runs one `tcopd` instance near its local observation and enforcement boundaries. Local telemetry reaches the local `tcopd`; a signed `tcopd`-to-`tcopd` exchange carries TCX context across domains; and the receiving `tcopd` invokes a local authorization interface. Only the middle boundary is cross-domain TCOP. The gateway receives a Domain-B-local decision, not the TCX context.

An interaction receipt is an opaque Domain-B-minted correlation handle. It is not an authorization token and does not grant enforcement authority. A receiver accepts a context only after validating signature, scope, expiry, authorized peer identity, replay state, and receipt correlation. It then combines the accepted context with locally held facts. This makes the trust boundary explicit: imported evidence can influence a local policy calculation, but no remote field maps directly to an enforcement action.

4 Receiver-Local Resolution and Enforcement

The receiving pipeline is context validation, local correlation, receiver-local strategy selection, receiver-local policy evaluation, receiver-local decision creation, and gateway enforcement. A gateway patch is intentionally generic: it calls a local authorization-evaluator interface and does not embed TCOP resolver or strategy logic. Authorization caching is disabled for correctness and counterfactual replay; a separately predeclared performance selection evaluates caching without changing the correctness path.

The evaluated authority invariant is strong: every gateway block must cite a Domain-B-local policy and decision, and remotely supplied TCX fields must never be interpreted as an enforcement action. The physical evaluation contains 30 gateway arms and records 0 remote enforcement successes. Its authorization audit and all physical blocks satisfy the Domain-B provenance requirement.

5 Containment Window

The containment window is action-relative. It is the interval in which imported context can change a receiver-local decision before a specified harmful action completes. Consequently, outside-window is incomplete unless it names the relevant action. A delivery after an initial harmful call can be outside the window for that call but inside the window for later calls.

This model prevents a misleading interpretation of late warnings. TCOP does not reverse completed harm. It can still enable a receiver to restrict subsequent opportunities if local correlation and policy make the context actionable before those opportunities. The evaluated timing labels therefore use causal action boundaries rather than a conversion from deterministic ticks to milliseconds.

6 Deterministic Evaluation

The deterministic evaluation compares isolated capable local observers (A1) against the same receiver configuration with valid imported context (A2). It holds local facts, local policy, strategy, and action inputs fixed before treatment effects. TCOP transports observations but creates no detections. Exact replay and frozen strategies make the paired result auditable.

For containment-first, the study includes 54 strict input-equivalent pairs. It improves 30, leaves 24 unchanged, worsens 0, and prevents 36 harmful actions. Figure 3 exposes the unchanged cases rather than presenting only improved cells.

The study deliberately excludes 123 candidate balanced and utility comparisons from causal A1/A2 inference because their receiver-local policies do not match. A fact-equivalent central audit includes 54 cells and finds 6 regressions associated with authority placement or central outage. This bounded comparison does not establish universal superiority to cen-

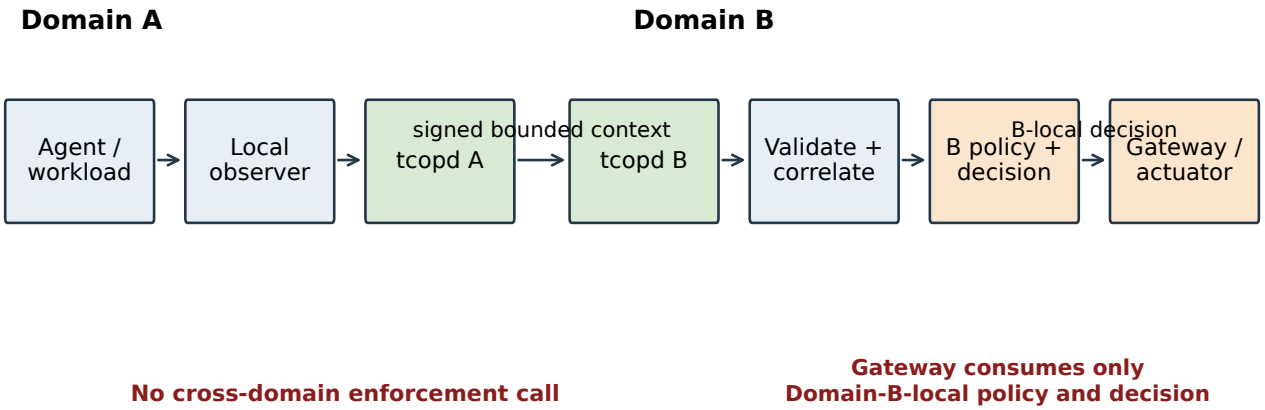


Figure 1: TCOP architecture and authority boundary. The cross-domain object is signed bounded context. Domain A cannot invoke Domain B enforcement; the gateway consumes a Domain-B-local policy and decision.

Table 2: Evaluative architecture roles. A2 is the receiver-sovereign TCOP configuration; the other rows are baselines, comparators, or upper bounds.

Architecture	Visibility	Authority	Outage dependence	Privacy exposure	Evaluative role
A0	None	None	N/A	None	No coordinated defense baseline
A1	Receiver-local	Domain B	Local only	Local only	Isolated capable observers
A2	Bounded exported facts	Domain B	Federation degrades to local operation	Bounded context	TCOP
A3	Equivalent exportable facts	Central service	Central decision path	Exported facts to central	Fact-equivalent central comparator
A4	Full telemetry	Central service	Central decision path	Full telemetry to central	Central upper bound
A5	Oracle	Oracle	Assumed	Oracle visibility	Oracle upper bound

Table 3: Strict deterministic containment-first comparison. Balanced and utility configurations with unmatched local policies are excluded.

Metric	Value
Strict input-equivalent pairs	54
Improved / unchanged / worsened	30/ 24/ 0
Harmful actions prevented	36
Unmatched-policy exclusions	123

tralized defense; it demonstrates that a receiver-local decision path avoids those specific evaluated dependencies.

6.1 Context versus blanket restriction

The separately rooted validation-value study holds receiver enforcement, action order, local facts, and warning arrival fixed across local-only (C0), arrival-only default-allow (C1-allow), arrival-only class guard (C1-class), validated matching (C2), and standing class restriction (C3). C1 policies receive only a valid-arrival token and TTL. C2 additionally evaluates issuer, signature, freshness, receipt, subject, resource namespace, capability class, scope, and receiver-local authorization state.

The preregistered credential-free cohort has twelve mixed-action episodes. On the three accepted matching harmful actions, C1-class and C2 each block all three. Across the full cohort, C1-class constrains seven benign actions while C2 constrains none; C3 blocks all twelve harmful and constrains all twelve benign actions. C1-allow forwards all actions. Deliberately wrong-subject, wrong-resource, wrong-receipt, expired, replayed, and semantic-smuggling warnings remain separately reported controls, not denominator contamination for the matching-action comparison. The same artifact records a valid-but-hostile peer burst study, correlation ambiguity at one, two, and eight concurrent sessions with zero cross-session restrictions, and signed-envelope mutation results. A valid signature authenticates the issuer, not the truth of its observation.

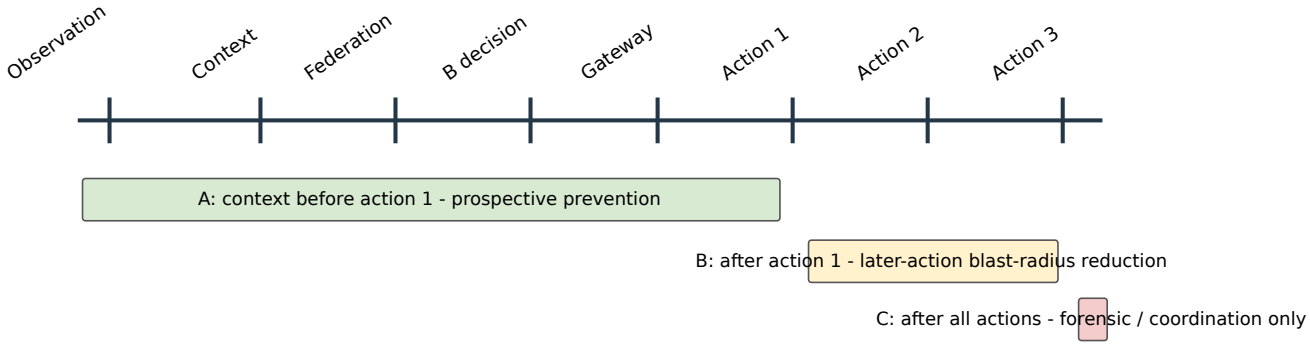


Figure 2: Containment-window model. Early context supports prospective prevention. Context after an initial action can reduce later blast radius. Context after all relevant actions has forensic or coordination value only.



Figure 3: Deterministic strict-pair outcomes. The full matched population includes improved and unchanged pairs; no pair worsened.

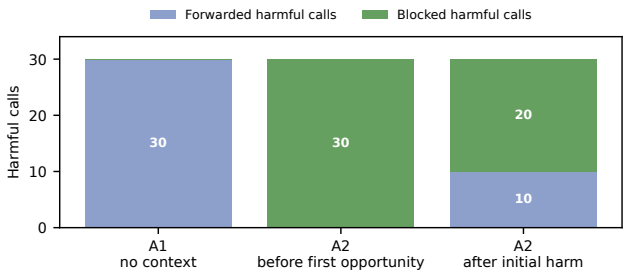


Figure 4: Physical end-to-end timing result. The late arm separates already forwarded harmful calls from subsequent calls blocked by a Domain-B-local decision.

7 Agent, Replay, and Gateway Evaluation

We separate live trace generation from causal evaluation. A credentialed model runtime generated action attempts in a bounded synthetic environment. The model did not judge security outcomes. The certified cohort contains 44 eligible traces with no model error or refusal recorded in the cohort. We freeze these action traces and compare treatments through strict replay, avoiding model nondeterminism in the paired evidence.

The strict replay matrix contains 220 paired comparisons. In the physical reference path, 20 signed exchanges traverse `tcopd`-A to `tcopd`-B, followed by a receiver-local evaluator and Docker MCP Gateway. Figure 4 shows a prospective arm, a no-context arm, and a late arm. The latter still blocks later opportunities but never claims to undo completed calls.

The reported sub-millisecond values are local deterministic harness measurements. They characterize implementation overhead within the test harness and do not estimate production or inter-organizational latency. The Docker MCP Gateway is a reference enforcement point, not a literal reproduction of a public defensive architecture.

Adaptive authorization boundary. The separately sealed adaptive-authorization study evaluates 20 frozen traces under five receiver policies, yielding 100 strict replay episodes. Every imported-evidence policy denies the initial exact-bound action. Exact matching alone permits 15 eligible post-denial harmful substitutions across capability, session, and delegation branches; the predeclared receiver-local campaign relation in C2E closes those branches in this reference model. Twelve bounded runtime episodes exercise the same declared branch graph and are reported separately from strict replay. These are policy-conditioned conformance results, not an estimate of adaptive behavior in deployment.

C2E selectivity frontier. The separately sealed C2E-frontier study evaluates 30 predeclared logical actions under the same five policies, yielding 150 deterministic episodes. C2E blocks all ten harmful actions, including all five

Table 4: Credentialed live trace cohort. Errors and refusals are counted before replay.

Scenario	Attempts	Eligible	Errors	Refusals	Primary harmful capability type
RA-01	12	12	0	0	Synthetic prompt-injection propagation: repository write and dataset export
RA-02	12	12	0	0	Synthetic credential and tool misuse: credential use, workload spawn, and dataset export
RA-03	20	20	0	0	None: frozen benign repository metadata write workflow
Total	44	44	0	0	Bounded synthetic cohort

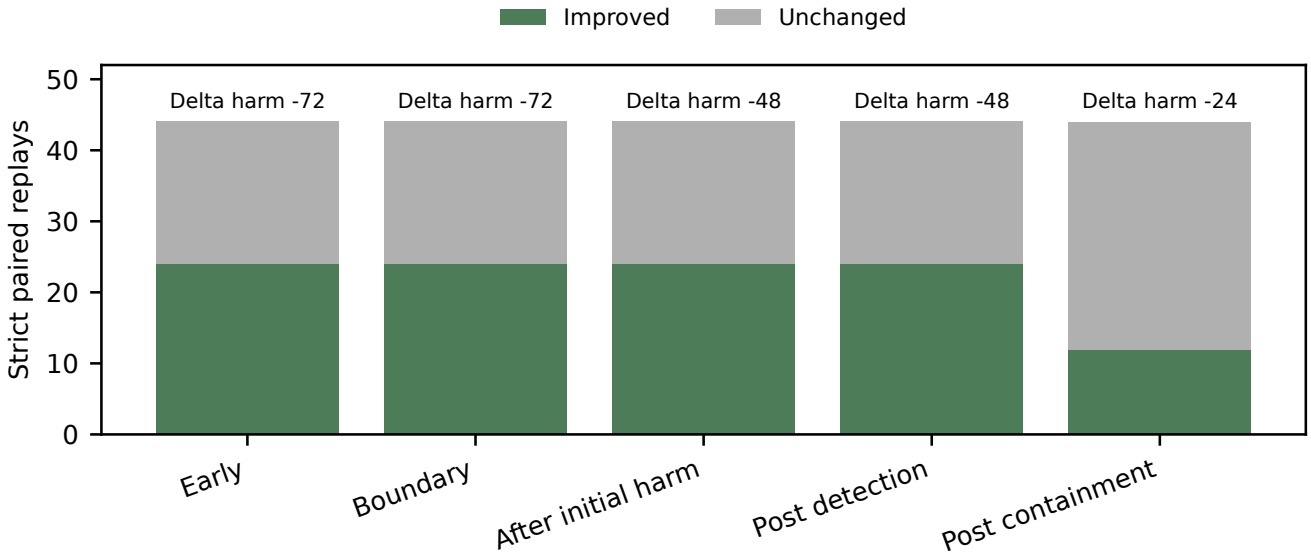


Figure 5: Strict replay results by action-relative delivery placement. Early and boundary treatments share the tested discrete preauthorization region.

Table 5: Physical end-to-end gateway arms. Each block is attributable to a Domain-B-local decision.

Arm	Forwarded	Blocked
A1, no context	30	0
A2, before first opportunity	0	30
A2, after initial harm	10	20

campaign-linked non-exact substitutions, while constraining none of the 20 benign actions. C1 and C3 block the same ten harmful actions but constrain ten benign same-risk actions; C2 constrains none but blocks only the five exact-bound harmful actions. In particular, C2E forwards all five benign same-risk actions outside the campaign that C1 and C3 constrain. Under the predeclared decision rule, this is a central policy-frontier result for the receiver-local reference model, not a claim about deployment prevalence or universal containment.

8 Security and Availability Analysis

The evaluation injects invalid signature, wrong receipt, expiry, replay, unknown peer, disallowed import type, monitor-only policy, receiver unavailability, authorization timeout, restart, stale decision, session termination, and late-context conditions. The expected behavior is rejection or a receiver-local disposition, never an origin-selected enforcement command.

Containment-first has a material availability cost in the selected synthetic false-warning treatments. Across the RA-03 replay treatments, 320 of 360 benign calls are forwarded and 40 are constrained. Workflow completion is 80 of 120 (66.7%). These values are not a universal false-positive rate; they quantify the chosen capability restriction and synthetic workload.

Independent warning admission. The separately sealed v2 independent-warning study uses AgentDojo run traces from pinned commit exttta75aba7 and the pinned Prompt Guard 2 86M revision exttta8ded8e. Before any receiver policy executes, it applies ascending SHA-256 selection to a fixed external trace reservoir and retains raw detector outputs for every

Table 6: Strict replay timing treatments. A treatment can be too late for one action while still affecting later opportunities.

Action-relative placement	Improved	Unchanged	Harmful-action delta
Before first harmful opportunity	24	20	-72
At first-action authorization boundary	24	20	-72
After initial harm, before later actions	24	20	-48
After receiver-local detection	24	20	-48
After partial local containment	12	32	-24

Table 7: Measured RA-03 availability cost under selected synthetic false-warning treatments and capability restriction; this is not a universal false-positive rate.

Treatment group	Attempted	Forwarded	Constrained	Workflow completion	Affected capability
Inside-window early and boundary	120	80	40	0/40	repository.write in frozen benign metadata workflow
No context, outside window, post-detection, and post-containment	240	240	0	80/80	no restriction in these treatments
All selected treatments	360	320	40	80/120(66.7%)	selected synthetic capability restriction

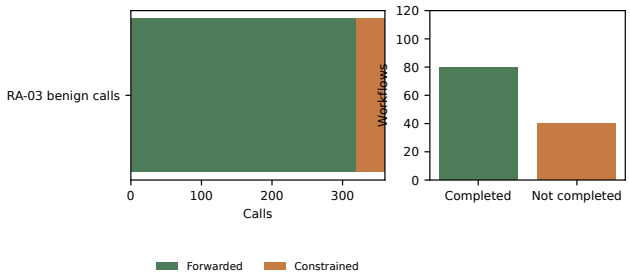


Figure 6: Measured RA-03 security–availability trade-off. The constrained calls and incomplete workflows are availability costs under the selected synthetic treatments.

candidate. The preflight observes 25 admitted attack-bearing warning candidates, 47 attack-bearing candidates normalized to no warning, and 96 benign candidates normalized to no warning; it then seals 12 external-positive exact cases and 12 external-negative cases. The normalizer maps the pinned model's runtime labels using the model card's published calibration prompt, rather than using corpus outcomes or receiver decisions.

Across the 24 external base cases, C2 and C2E block all 12 valid exact-bound harmful actions and forward all 12 benign no-warning actions; C3 also blocks the harmful actions but constrains the 12 benign actions. Deterministic controls remain distinct from external cases: C2 and C2E do not restrict partial or mismatched bindings, stale or replayed candidates are rejected before policy restriction, and sender-suggested-only relations do not restrict under C2E. Exact binding forwards all 12 substitutions without a receiver-created relation; campaign correlation blocks all 12 paired substitutions only after the receiver records a local relation. These are frozen-cohort receiver-disposition results, not estimates of detector quality, warning prevalence, or deployment effectiveness.

9 Related Work

TCOP intersects several bodies of work but has a distinct authority boundary. Threat-intelligence exchange systems, including STIX/TAXII and MISP, distribute indicators and reports; TCOP distributes signed bounded runtime context intended for a receiver-local action-time correlation. Zero-trust, workload-identity, remote-attestation, and policy decision/enforcement systems provide relevant identity and local-control mechanisms. Distributed and cooperative intrusion-response systems address coordination but can differ in exchanged object, decision location, and enforcement authority. Agent sandbox runtimes that enforce filesystem, process, and egress policy outside the agent process, such as NVIDIA OpenShell in NemoClaw [3], supply a receiver-local boundary of the kind TCOP assumes; they decide what an agent may reach but carry no cross-domain evidence about what it has been observed doing, which is the gap TCOP addresses.

Agent security and prompt-injection defenses motivate the synthetic action traces and reference gateway. They do not by themselves establish a cross-domain authority model. A complete related-work matrix, with verified citations and concrete distinctions in trust model, exchanged object, policy location, enforcement location, timing, and provenance, remains a draft-mode TODO. This draft makes no first-system or no-prior-work claim.

10 Limitations and Conclusion

The evaluation uses synthetic tools and attack scenarios, a limited set of malicious scenario classes, receipt-based correlation in the evaluated path, one reference gateway, local harness

Table 8: Negative and failure controls. All listed conditions passed in the sealed live artifact.

Injected condition	Expected behavior	Observed behavior	Invariant	Pass	Source record
Invalid signature	Reject before restriction	Rejected; no restriction	Signed input	Yes	NC-01
Wrong receipt	Reject before restriction	Rejected; no restriction	Receipt correlation	Yes	NC-02
Expired context	Reject before restriction	Rejected; no restriction	Bounded freshness	Yes	NC-03
Replayed context	Reject before restriction	Rejected; no restriction	Replay protection	Yes	NC-04
Unknown peer	Reject before restriction	Rejected; no restriction	Authorized peer	Yes	NC-05
Disallowed import type	Reject before restriction	Rejected; no restriction	Context class	Yes	NC-06
Monitor-only policy	Do not preempt first call	First call not blocked	Local detection timing	Yes	NC-07
No remote enforcement	Never accept remote enforcement	No remote action used	Receiver authority	Yes	NC-08
Remote TCX action	Never interpret remote action	No remote action used	Receiver authority	Yes	NC-09
Gateway cache disabled	Evaluate each authorization	Cache disabled	Replay correctness	Yes	NC-10
tcopd B unavailable	Use B-local disposition	Local fail-closed policy	Receiver authority	Yes	NC-11
Authorization timeout	Use B-local disposition	Sender does not choose timeout	Receiver authority	Yes	NC-12
Gateway restart	Recompute local state	Fresh decision used	Receiver authority	Yes	NC-13
Stale decision	Recompute local state	Fresh decision used	Receiver authority	Yes	NC-14
Session termination before arrival	Do not cross sessions	Context has no new session effect	Session binding	Yes	NC-15
Arrival after local containment	No reversal of completed action	Non-preventive late context	Containment window	Yes	NC-16

Table 9: Local harness performance. These deterministic local measurements characterize implementation overhead in the test harness and are not production inter-domain latency estimates.

Selection	Authorization p95 (ms)	Gateway p95 (ms)	Warning-to-enforcement p95 (ms)	Cache hit rate
Disabled	0.019750	0.024584	0.331624	0.00
Enabled, fixed 5s TTL	0.000667	0.027250	0.328208	0.95

performance measurements, and one frozen model/runtime selection. Strict action-trace replay approximates adaptive behavior after denial; it does not model an agent that changes its strategy after each blocked call. TCOP is not evaluated on a production incident, Internet-scale federation, or real-world attack frequency.

TCOP is useful only when a participating observer detects a useful fact in time and the receiver has an enforceable local boundary. It cannot create detections, guarantee observation truth, prevent an undetected origin compromise, or reverse completed harm. The evaluated central comparison is bounded and does not support universal claims about centralized defense.

Within those limits, the evidence supports a systems-security conclusion: signed bounded context can reduce downstream blast radius when it becomes actionable inside a containment window, while preserving receiver-local decision authority. The accompanying artifact makes the frozen deterministic and replay results reproducible without live-model credentials and retains the observed availability cost as part of the design trade-off.

Future work: an independent sandbox runtime as the receiver boundary. The physical reference path in Section 7 enforces Domain-B decisions through a reference gateway that we built, and the two `tcopd` endpoints ran as separate processes rather than on separately administered hosts. The pre-registered cross-host study (Appendix D) already requires two distinct non-local hosts and remains sealed as a blocked artifact. We intend to execute it with the receiver boundary supplied by an independently maintained agent sandbox runtime rather than our reference gateway. Out-of-process runtimes such as NVIDIA OpenShell, as packaged in NemoClaw, expose a declarative policy over filesystem, process, network egress, and inference routing, with deny-by-default egress and an operator approval path for policy change. Such a runtime is a receiver-local enforcement point in the sense this paper requires: it is outside the agent process, it does not depend on the agent's cooperation, and it already distinguishes allowed destinations from unknown ones. TCOP's role in that configuration is narrow and testable. A validated TCX may only tighten the runtime policy (remove an egress destination, revoke a credential scope, freeze or snapshot the sandbox); it may never widen it, and it never issues the enforcement call itself. The planned arm places two live agents on two hosts in declared adversarial roles, with Domain A observing and signing, Domain B deciding through the runtime policy, and the same five fixed adaptive branches of Amendment 002 driving the attacker. The July 2026 Hugging Face intrusion [1, 2] is the motivating case: every cross-domain step in that incident was an allowed network call from the agent's own side, which a per-action approval gate cannot distinguish from benign use and a receiver-side egress policy can, provided the observing domain's evidence reaches it in time. The claim boundary is unchanged: where receiver-bound evidence would have had a role, not that it would have stopped the incident.

Table 10: Live runtime amendment history. Digest prefixes identify the immutable predecessor and successor roots; full digests are retained in the normalized amendment-chain data and source-verification report. The first two predecessor artifacts are retained provider-failure negatives.

Amendment	Cause	Model sampling?	Traces?	Protocol / policy?	Result derivation?	Predecessor digest	Successor digest
001	Provider completion-token field	No successful sampling	No	No	No	e5cf49806b70	698ca3c116af
002	Provider reasoning mode	No	No	No	No	698ca3c116af	f9bccfcaeff8
003	RA-03 eligibility aligned to frozen truth	Yes, eligible cohort capture	No	No	Eligibility only	f9bccfcaeff8	cebc669a7a3c
004	Completion-gate ordering	No	No	No	No	cebc669a7a3c	24a20e9c48a2
005	Derived utility reconciliation	No	No	No	Yes, replay-row aggregation	24a20e9c48a2	2b1f92ff4481
006	Physical tcopd-a relay replay	No	No	No	Physical-path evidence	2b1f92ff4481	546f3547b727

Table 11: What the evaluation supports and does not support.

Evidence	Supported scope
Deterministic matched pairs	Causal comparison under matched frozen local policy and synthetic scenarios
Executable replay	Exact captured action-sequence comparison without model credentials
Live trace generation	A bounded credentialed cohort generated action attempts
Physical federation and reference gateway	A signed tcopd-A-to-tcopd-B path and receiver-local gateway decisions
Not established	Production deployment, Internet-scale federation, uninstrumented incidents, or universal superiority to central defense

References

[1] Hugging Face. Technical timeline of the July 2026 agent intrusion. https://huggingface.co/blog/agent-intrusion-technical-timeline, 2026.

[2] METR. Investigation of the OpenAI Hugging Face incident. https://metr.org/blog/2026-08-26-openai-hugging-face-incident-investigation/, August 2026.

[3] NVIDIA Corporation. NemoClaw: An open source reference stack for running AI agents inside OpenShell sandboxes. https://github.com/NVIDIA/NemoClaw, 2026. Announced at GTC, March 16, 2026. Alpha software.

[4] USENIX Association. Templates for conference papers. https://www.usenix.org/conferences/author-resources/paper-templates. Accessed for the anonymous draft build.

A Open Science Appendix

The artifact is organized around four reproduction tiers. Tier 0 verifies immutable artifact roots, normalizes data, regenerates figures and tables, audits manuscript numbers, and builds the paper. Tier 1 reruns the deterministic causal-core study without external credentials. Tier 2 strictly replays frozen agent traces through local-only and TCOP treatments, again without model credentials. Tier 3 is an optional credentialed regeneration of live traces and is not required for the paper's causal findings.

The artifact uses Python, the repository's existing TCOP CLI, Matplotlib for vector figures, and a TeX distribution for the draft PDF. Docker is required only for the optional reference-gateway smoke path. Raw source artifacts remain at repository-relative paths; normalized data, analysis scripts, figures, tables, and expected outputs live under the paper workspace. The anonymous artifact URL is a draft-mode TODO to be supplied by human authors before submission.

Tier 0 and Tier 2 complete without provider credentials. Tier 3 documents its provider/runtime lock, eligibility criteria, bounded attempts, expected variability, and cost category separately from frozen-trace reproduction.

B Ethics Appendix

All evaluated tools and target systems are synthetic. No production credentials, real repositories, customer systems, datasets, or workloads were attacked. Prompts and tool calls are restricted to a test environment, and no autonomous production enforcement occurred. The credentialed model activity was bounded by synthetic tool interfaces. No human subjects were involved.

Any public-incident discussion is a counterfactual motivation, not an attribution or empirical reconstruction. Release risk is reduced by synthetic examples and bounded configuration. Human authors remain responsible for all AI-assisted text, code, data interpretation, and citations.

C Frozen Strategy Details

The study certifies four objective-specific frozen configurations: containment-first (P2), balanced federated (V05_CONSOLIDATION_REDUCED), utility-preserving (F-10110000), and forensic-oriented (P7). The paper's primary causal deterministic comparison uses containment-first because it is the configuration with matched local-policy pairs. Balanced and utility configurations are retained in the artifact but their unmatched comparisons are excluded from the causal claim.

The full manifest digests and certification status appear in the source-verification report and normalized strategy records. The paper does not portray the forensic configuration as a separable composable overlay, and it makes no unsupported reconstruction-quality claim.

D Live Amendment History

The live evaluation preserves a visible sequence of sealed artifacts. The earliest provider-failure artifacts remain negative results. Amendments correct provider transport compatibility, align frozen benign eligibility, correct an artifact completion gate, reconcile a derived utility counter from immutable replay rows, and add the physical origin relay without new model sampling. None changes TCX fields, policies, prompts, tools, treatment definitions, or frozen traces.

E Extended Results

The normalized data preserves the full strict-pair and treatment-level rows with source artifact digests, paths, and row identifiers. The timing result distinguishes delivery before the first harmful opportunity, at the first-action authorization boundary, after initial harm but before later actions, after receiver-local detection, and after partial local containment. No figure interpolates a causal effect between these measured placements.

The selected utility result is intentionally reported alongside security benefit. Restriction expiry and recovery remain receiver-local, and the artifact retains the raw treatment rows required to inspect the completion calculation.

F Failure Controls

The controls exercise invalid signatures, receipt mismatch, expiry, replay, unauthorized peers, unsupported imports, local monitor-only behavior, receiver unavailability, timeout, gateway restart, stale decisions, session binding, and late delivery. In every evaluated gateway block, the recorded enforcement provenance is Domain-B-local. The source reports separately record opaque receipt validation and zero remote enforcement success. The complete generated control table appears in the body; the normalized control rows preserve the individual source records.

G Reproducibility Details

The default reviewer workflow avoids live credentials. It verifies source roots, regenerates all paper-local derivatives, and invokes strict replay on frozen traces. Exact expected counts and full source digests are machine-checkable in the anonymous artifact manifest. The deterministic causal-core tier writes a new output root and compares its declared deterministic results; it never overwrites the sealed sources.

The live provider environment is documented only for optional trace regeneration. A current provider response can differ from the frozen cohort; such a replication does not replace the trace-replay evidence or modify the paper's claims.

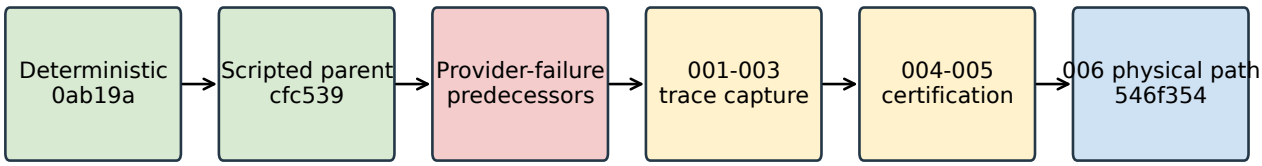


Figure 7: Artifact and amendment lineage. Short prefixes identify roots; the source-verification report records full digests and predecessor links.